

ОТЧЁТ

по практической работе

CMD Injection и PHP Code Injection

Выполнил: Аньшин Сергей

2026

Цель работы и среда

Изучить CMD Injection и PHP Code Injection на учебном веб-приложении, установить причины уязвимостей и способы защиты. Порядок разделов соответствует исходному отчёту. Скриншоты отражают ход работы на локальном стенде; повторяющиеся и пустые кадры исключены.

1. CMD Injection

CMD Injection возникает, когда недоверенный параметр объединяется с командой операционной системы. Учебная страница `whois.php` принимает домен или IP-адрес и выводит ответ Whois.

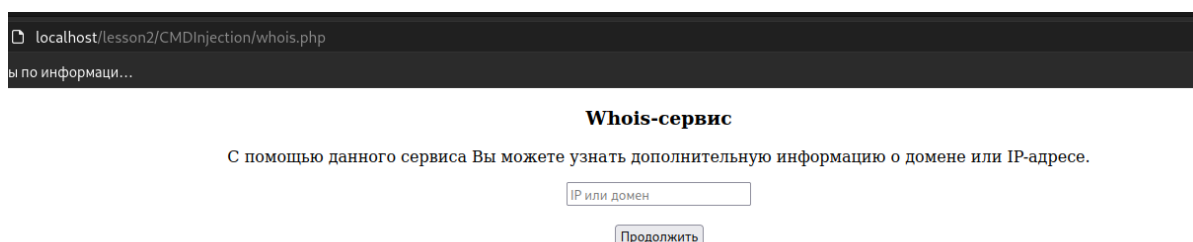


Рисунок 1. Исходная форма Whois. Открыта учебная страница `whois.php` с полем для домена или IP-адреса.

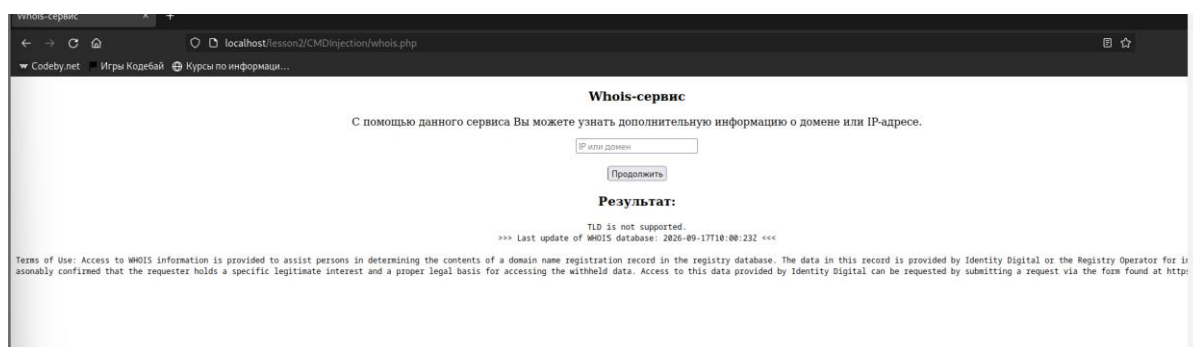


Рисунок 2. Результат обычного запроса Whois. Страница выводит ответ сервиса Whois; это контрольный пример работы формы до анализа внедрения.

1.1. Разбор `whois.php`

Сначала был проверен обычный ответ сервиса. Затем изучен исходный код приложения: в исходном варианте аргумент команды экранировался. На следующем снимке показана учебная модификация вызова `system()`, после которой ввод передаётся командному интерпретатору без прежней защиты.

```

(student@codeby)-[~]
$ cat /var/www/html/lesson2/CMDInjection/whois.php
<!DOCTYPE html>
<html lang="ru">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Whois-сервис</title>
</head>
<body>
  <div align="center">
    <h3>Whois-сервис</h3>
    <p>С помощью данного сервиса Вы можете узнать дополнительную информацию о домене или IP-адресе.</p>
    <form method="POST" action="/lesson2/CMDInjection/whois.php">
      <input name="target" placeholder="IP или домен" autocomplete="off"> <br><br>
      <button name="submit" value="submit">Продолжить</button>
    </form>
    <?php
    if (isset($_POST['submit'])) {
      $target = $_POST['target'];
      echo "<h3>Результат:</h3>";
      echo "<pre>";
      system("whois " . escapeshellarg($target));
      echo "</pre>";
    }
    ?>
  </div>
</body>
</html>

```

Рисунок 3. Исходный код whois.php. В исходном коде видно, что аргумент передаётся в системную команду через `escapeshellarg($target)`.

```

Файл Действия Правка Вид Справка
GNU nano 7.2 /var/www/html/lesson2/CMDInjection/
<!DOCTYPE html>
<html lang="ru">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Whois-сервис</title>
</head>
<body>
  <div align="center">
    <h3>Whois-сервис</h3>
    <p>С помощью данного сервиса Вы можете узнать дополнительную информацию о домене или IP-адресе.</p>
    <form method="POST" action="/lesson2/CMDInjection/whois.php">
      <input name="target" placeholder="IP или домен" autocomplete="off"> <br><br>
      <button name="submit" value="submit">Продолжить</button>
    </form>
    <?php
    if (isset($_POST['submit'])) {
      $target = $_POST['target'];
      echo "<h3>Результат:</h3>";
      echo "<pre>";
      system("whois $target");
      echo "</pre>";
    }
    ?>
  </div>
</body>
</html>

```

Рисунок 4. Изменённый вызов системной команды. В учебном файле показан вызов `system` с прямой подстановкой `$target` без прежнего экранирования.

Появление `www-data` и `uid=33(www-data)` на странице Whois подтверждает исполнение дополнительной команды в контексте процесса веб-сервера. Эти результаты относятся к локальному учебному приложению.

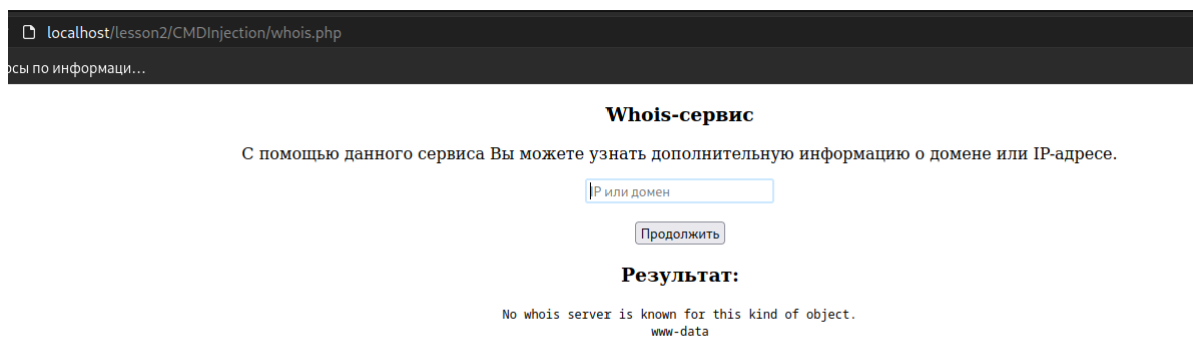


Рисунок 5. Результат whoatі через форму. В ответе Whois появилась строка *www-data*, указывающая на выполнение команды от имени веб-сервера.

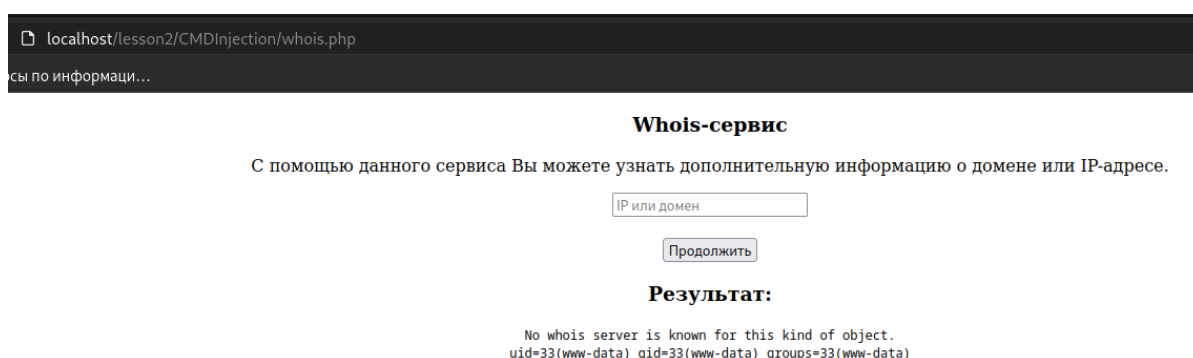


Рисунок 6. Подтверждение идентификатора веб-сервера. Вывод *uid=33(www-data)* и *gid=33(www-data)* уточняет контекст выполнения команды.

2. PHP Code Injection

PHP Code Injection связана с выполнением введенной строки как PHP-кода. В *calculator.php* выражение из поля формы передается в *eval()*. Поэтому поле калькулятора может влиять не только на арифметический результат.

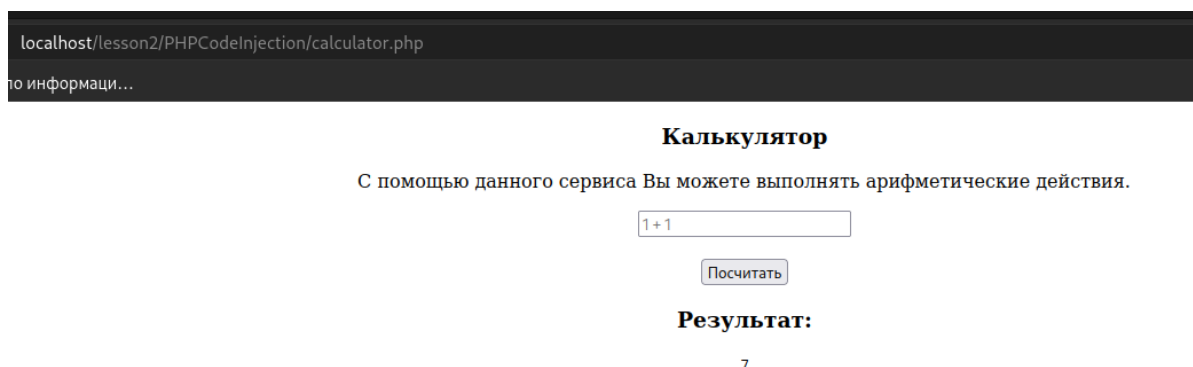


Рисунок 7. Форма учебного калькулятора. Открыта страница *calculator.php* с полем арифметического выражения и результатом.

2.1. Разбор eval()

В представленном исходном коде параметр `expression` из POST-запроса используется при формировании строки для `eval()`. В отличие от обычного вычисления выражения, `eval()` интерпретирует её как код PHP. Скриншот результата показывает вывод `www-data`.

```
(student@codeby)-[~]
$ cat /var/www/html/lesson2/PHPCODEInjection/calculator.php
<!DOCTYPE html>
<html lang="ru">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Калькулятор</title>
</head>
<body>
  <div align="center">
    <h3>Калькулятор</h3>
    <p>С помощью данного сервиса Вы можете выполнять арифметические действия.</p>
    <form method="POST" action="/lesson2/PHPCODEInjection/calculator.php">
      <input name="expression" placeholder="1 + 1" autocomplete="off"> <br><br>
      <button name="submit" value="submit">Посчитать</button>
    </form>
    <?php
    if (isset($_POST['submit'])) {
      $expression = $_POST['expression'];
      echo "<h3>Результат:</h3>";
      echo "<pre>";
      echo eval('return ' . $expression . ';');
      echo "</pre>";
    }
    ?>
  </div>
</body>
</html>

(student@codeby)-[~]
```

Рисунок 8. Исходный код `calculator.php`. В коде видно применение `eval()` к выражению из POST-параметра `expression`.

Калькулятор

С помощью данного сервиса Вы можете выполнять арифметические действия.

Результат:

www-data
www-data

Рисунок 9. Вывод калькулятора после проверки. На странице калькулятора отображаются строки `www-data`, что подтверждает выполнение в контексте веб-сервера.

2.2. Подключение к слушателю

Терминал сначала показывает ожидание подключения на порту 9898. На новом снимке зафиксировано локальное подключение с адреса 127.0.0.1 и выполнение команд внутри полученной оболочки. Вывод `whoami` и `id` подтверждает пользователя `www-data` с `uid=33`. Отказ в доступе к каталогу `student` показывает ограничение прав этого пользователя.

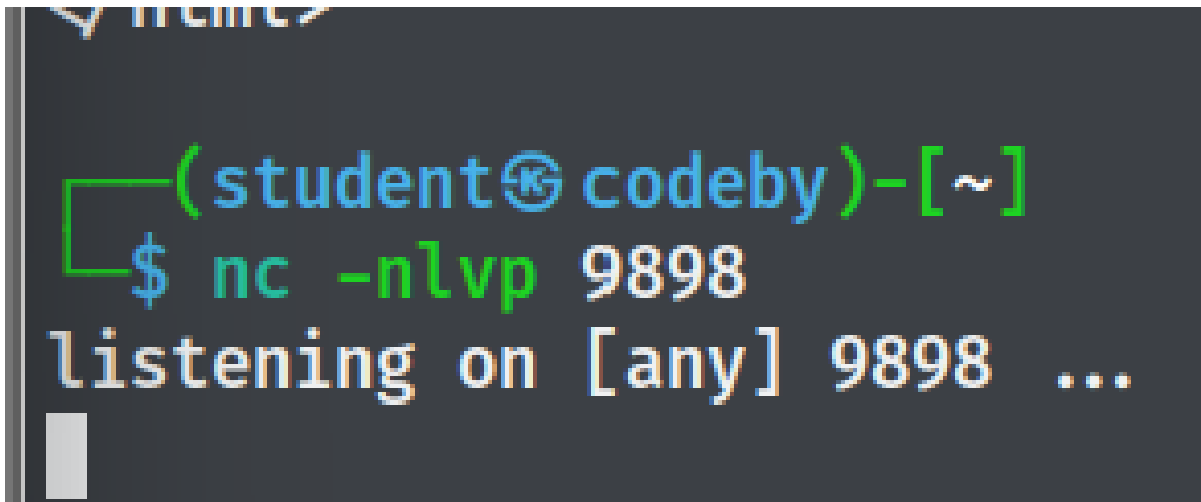


Рисунок 10. Запущенный слушатель. Терминал показывает ожидание подключения на порту 9898. Подключение на снимке не показано.

```
(student@codeby)-[~]  
$ nc -nlvp 9898  
listening on [any] 9898 ...  
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 45500  
sh: 0: can't access tty; job control turned off  
$ whoami; id  
www-data  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
$ ls /home/student/  
ls: cannot open directory '/home/student/': Permission denied  
$ cat /etc/passwd  
root:x:0:0:root:/root:/usr/bin/zsh  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin
```

Рисунок 11. Подключение к слушателю и проверка контекста. В терминале показано локальное подключение к порту 9898. Команды `whoami` и `id` подтверждают выполнение от имени `www-data` с `uid=33`; попытка открыть домашний каталог `student` завершилась отказом в доступе.

2.3. Сравнение

В сценарии CMD Injection пользовательский ввод влияет на команду операционной системы, вызванную через `system()`. В сценарии PHP Code Injection ввод сначала интерпретируется функцией `eval()` как PHP-код. Оба механизма могут привести к выполнению команд от имени веб-сервера; в материалах это подтверждено выводом `www-data`.

3. Защита и выводы

Не следует передавать пользовательский ввод в `eval()` или собирать из него строку системной команды. Для Whois нужна проверка допустимого формата домена или IP-адреса и вызов без интерпретации `shell`. Для калькулятора следует разбирать только разрешённые числа, скобки и арифметические операции безопасным парсером.

В работе подтверждено выполнение команд от имени `www-data` через учебную страницу Whois и вывод `www-data` через калькулятор. Дополнительный снимок подтверждает подключение к слушателю и работу оболочки от имени `www-data`. По одному снимку терминала нельзя однозначно установить, какой из двух способов внедрения вызвал это подключение.

Материалы: исходный отчёт «Отчёт_CMD_PHP_Injection.pdf», снимки экрана от 17 сентября 2026 года и дополнительный снимок терминала.